

Day 4 Course Book – Web Application Security Fundamentals

Structured as a self-study handbook with definitions, explanations, workflows, examples, scenarios, interview questions, and key takeaways.

1. Web Application Security Introduction

Definition

Web application security is the practice of protecting web applications, users, and data from attacks.

Why It Is Important

Understanding this topic helps identify security weaknesses and apply controls before attackers can exploit them.

Workflow

User → Web Application → Database → Valuable Data

Example

A banking website stores customer information and transaction details. Security controls are required to protect them.

Scenario

A practical scenario was discussed during Day 4 to understand how the concept appears in real applications and how security controls reduce risk.

Interview Questions

What is this concept? Why is it important? Give an example. Explain the workflow. How can risks be reduced?

Key Takeaways

Remember the definition, workflow, real-world example, and mitigation strategy.

2. Asset

Definition

An asset is anything valuable that requires protection.

Why It Is Important

Understanding this topic helps identify security weaknesses and apply controls before attackers can exploit them.

Workflow

Customer Data → Asset → Protection Required

Example

Examples: databases, accounts, payment information, application servers.

Scenario

A practical scenario was discussed during Day 4 to understand how the concept appears in real applications and how security controls reduce risk.

Interview Questions

What is this concept? Why is it important? Give an example. Explain the workflow. How can risks be reduced?

Key Takeaways

Remember the definition, workflow, real-world example, and mitigation strategy.

3. Threat

Definition

A threat is anything capable of exploiting a vulnerability.

Why It Is Important

Understanding this topic helps identify security weaknesses and apply controls before attackers can exploit them.

Workflow

Threat → Exploit Attempt → Target System

Example

Examples: attacker, malicious insider, automated bot.

Scenario

A practical scenario was discussed during Day 4 to understand how the concept appears in real applications and how security controls reduce risk.

Interview Questions

What is this concept? Why is it important? Give an example. Explain the workflow. How can risks be reduced?

Key Takeaways

Remember the definition, workflow, real-world example, and mitigation strategy.

4. Vulnerability

Definition

A vulnerability is a weakness that can be exploited.

Why It Is Important

Understanding this topic helps identify security weaknesses and apply controls before attackers can exploit them.

Workflow

Weakness → Vulnerability → Exploitation

Example

Examples: weak passwords, poor validation, insecure coding.

Scenario

A practical scenario was discussed during Day 4 to understand how the concept appears in real applications and how security controls reduce risk.

Interview Questions

What is this concept? Why is it important? Give an example. Explain the workflow. How can risks be reduced?

Key Takeaways

Remember the definition, workflow, real-world example, and mitigation strategy.

5. Risk

Definition

Risk is the potential impact when a threat exploits a vulnerability.

Why It Is Important

Understanding this topic helps identify security weaknesses and apply controls before attackers can exploit them.

Workflow

Asset + Threat + Vulnerability → Risk

Example

Example: customer database exposed due to weak authentication.

Scenario

A practical scenario was discussed during Day 4 to understand how the concept appears in real applications and how security controls reduce risk.

Interview Questions

What is this concept? Why is it important? Give an example. Explain the workflow. How can risks be reduced?

Key Takeaways

Remember the definition, workflow, real-world example, and mitigation strategy.

6. Threat Modeling

Definition

Threat modeling identifies assets, threats, vulnerabilities, and risks before deployment.

Why It Is Important

Understanding this topic helps identify security weaknesses and apply controls before attackers can exploit them.

Workflow

Identify Assets → Threats → Vulnerabilities → Risks → Controls

Example

Used during design to reduce security issues early.

Scenario

A practical scenario was discussed during Day 4 to understand how the concept appears in real applications and how security controls reduce risk.

Interview Questions

What is this concept? Why is it important? Give an example. Explain the workflow. How can risks be reduced?

Key Takeaways

Remember the definition, workflow, real-world example, and mitigation strategy.

7. OWASP

Definition

OWASP provides guidance for common web application security risks.

Why It Is Important

Understanding this topic helps identify security weaknesses and apply controls before attackers can exploit them.

Workflow

Build App → Review OWASP Risks → Fix Issues

Example

OWASP Top 10 helps prioritize major security concerns.

Scenario

A practical scenario was discussed during Day 4 to understand how the concept appears in real applications and how security controls reduce risk.

Interview Questions

What is this concept? Why is it important? Give an example. Explain the workflow. How can risks be reduced?

Key Takeaways

Remember the definition, workflow, real-world example, and mitigation strategy.

8. SQL Injection

Definition

SQL Injection occurs when untrusted input influences SQL query behavior.

Why It Is Important

Understanding this topic helps identify security weaknesses and apply controls before attackers can exploit them.

Workflow

User Input → Application → SQL Query → Database

Example

Danger: attacker-controlled input may alter intended query logic.

Scenario

A practical scenario was discussed during Day 4 to understand how the concept appears in real applications and how security controls reduce risk.

Interview Questions

What is this concept? Why is it important? Give an example. Explain the workflow. How can risks be reduced?

Key Takeaways

Remember the definition, workflow, real-world example, and mitigation strategy.

9. Parameterized Queries

Definition

Parameterized queries separate SQL structure from user data.

Why It Is Important

Understanding this topic helps identify security weaknesses and apply controls before attackers can exploit them.

Workflow

User Input → Parameterized Query → Database

Example

Primary defense against SQL Injection.

Scenario

A practical scenario was discussed during Day 4 to understand how the concept appears in real applications and how security controls reduce risk.

Interview Questions

What is this concept? Why is it important? Give an example. Explain the workflow. How can risks be reduced?

Key Takeaways

Remember the definition, workflow, real-world example, and mitigation strategy.

10. XSS Introduction

Definition

Cross-Site Scripting affects the victim's browser rather than the database.

Why It Is Important

Understanding this topic helps identify security weaknesses and apply controls before attackers can exploit them.

Workflow

Attacker Input → Website → Victim Browser

Example

Occurs when untrusted content is rendered unsafely.

Scenario

A practical scenario was discussed during Day 4 to understand how the concept appears in real applications and how security controls reduce risk.

Interview Questions

What is this concept? Why is it important? Give an example. Explain the workflow. How can risks be reduced?

Key Takeaways

Remember the definition, workflow, real-world example, and mitigation strategy.

11. Stored XSS

Definition

Malicious content is stored and later served to users.

Why It Is Important

Understanding this topic helps identify security weaknesses and apply controls before attackers can exploit them.

Workflow

Attacker → Database → Victim Browser

Example

One payload can affect many visitors.

Scenario

A practical scenario was discussed during Day 4 to understand how the concept appears in real applications and how security controls reduce risk.

Interview Questions

What is this concept? Why is it important? Give an example. Explain the workflow. How can risks be reduced?

Key Takeaways

Remember the definition, workflow, real-world example, and mitigation strategy.

12. Reflected XSS

Definition

Input is reflected back immediately in the response.

Why It Is Important

Understanding this topic helps identify security weaknesses and apply controls before attackers can exploit them.

Workflow

Malicious URL → Server Response → Victim Browser

Example

Usually requires the victim to open a crafted link.

Scenario

A practical scenario was discussed during Day 4 to understand how the concept appears in real applications and how security controls reduce risk.

Interview Questions

What is this concept? Why is it important? Give an example. Explain the workflow. How can risks be reduced?

Key Takeaways

Remember the definition, workflow, real-world example, and mitigation strategy.

13. DOM XSS

Definition

The issue exists in client-side JavaScript and DOM manipulation.

Why It Is Important

Understanding this topic helps identify security weaknesses and apply controls before attackers can exploit them.

Workflow

URL/Input → Browser JS → DOM → Browser

Example

Occurs without database storage.

Scenario

A practical scenario was discussed during Day 4 to understand how the concept appears in real applications and how security controls reduce risk.

Interview Questions

What is this concept? Why is it important? Give an example. Explain the workflow. How can risks be reduced?

Key Takeaways

Remember the definition, workflow, real-world example, and mitigation strategy.

14. Input Validation

Definition

Input validation checks whether data matches expected rules.

Why It Is Important

Understanding this topic helps identify security weaknesses and apply controls before attackers can exploit them.

Workflow

User Input → Validation → Accept/Reject

Example

Checks include type, format, range, and length.

Scenario

A practical scenario was discussed during Day 4 to understand how the concept appears in real applications and how security controls reduce risk.

Interview Questions

What is this concept? Why is it important? Give an example. Explain the workflow. How can risks be reduced?

Key Takeaways

Remember the definition, workflow, real-world example, and mitigation strategy.

15. Secure Coding

Definition

Secure coding reduces vulnerabilities through defensive development practices.

Why It Is Important

Understanding this topic helps identify security weaknesses and apply controls before attackers can exploit them.

Workflow

Input → Validation → Secure Logic → Safe Processing

Example

Includes parameterized queries, password hashing, and least privilege.

Scenario

A practical scenario was discussed during Day 4 to understand how the concept appears in real applications and how security controls reduce risk.

Interview Questions

What is this concept? Why is it important? Give an example. Explain the workflow. How can risks be reduced?

Key Takeaways

Remember the definition, workflow, real-world example, and mitigation strategy.

Day 4 Summary

Topics completed: Asset, Threat, Vulnerability, Risk, Threat Modeling, OWASP, SQL Injection, Parameterized Queries, XSS, Stored XSS, Reflected XSS, DOM XSS, Input Validation, and Secure Coding. Key takeaway: Never trust user input.